BÁO CÁO KIỂM THỬ MIỀN GIÁ TRỊ VÀ PHÂN TÍCH GIÁ TRỊ BIÊN

TÍNH NĂNG FR-08: THANH TOÁN (CHECKOUT) (POOL B)

- **Mã sinh viên:** 23120127
- **Họ và tên:** Dương Trọng Hòa
- **Hệ thống được kiểm thử (SUT):** EShop Platform (`http://localhost:5173` / Backend API `http://localhost:3000`)
- **Kỹ thuật áp dụng:** Domain Testing (Equivalence Partitioning - EP) & Boundary Value Analysis (3-Value BVA theo chuẩn ISTQB)
- **Thời gian thực hiện:** 2026-10-18

---

1. ĐẶC TẢ YÊU CẦU & PHÂN TÍCH BIẾN ĐẦU VÀO (SPECIFICATION ANALYSIS)

1.1 Trích xuất đặc tả FR-08 từ System Requirements Specification

> - **FR-08: Thanh toán (Checkout)**
>   - Chỉ người dùng **đã đăng nhập** mới tiến hành thanh toán được.
>   - **Tổng tiền thanh toán** được tính tự động từ giỏ hàng và không cho phép người dùng chỉnh sửa trực tiếp.
>   - Giao diện hiển thị đầy đủ danh sách sản phẩm đặt mua.
>   - Backend phải tự tính lại tổng tiền; **không chấp nhận** giá trị `total_amount` do client gửi lên.
>   - Sau thanh toán thành công, **giỏ hàng được xóa**.
> - **Ràng buộc giao diện & dữ liệu bổ trợ (FR-21, FR-22, FR-18, SEC-02, SEC-04):**
>   - Địa chỉ giao hàng (`shipping_address`): Là trường bắt buộc (có dấu `*` đỏ cạnh nhãn theo FR-22), độ dài từ 1–255 ký tự, không render HTML/JavaScript (SEC-04).
>   - Giỏ hàng (`items`): Danh sách sản phẩm phải có tối thiểu 1 sản phẩm (≥ 1). Không thể thanh toán khi giỏ rỗng.
>   - Số lượng (`quantity`): Bắt buộc là số nguyên dương ≥ 1 (FR-06, FR-07), cấm số 0 hoặc số âm.
>   - Mỗi trang có đúng 1 thẻ `<h1>`, đơn vị tiền tệ dùng ký hiệu `đ` có phân cách hàng nghìn (FR-21).

1.2 Điều kiện tiên quyết (Preconditions)

- Người dùng đã đăng nhập thành công vào hệ thống với tài khoản hợp lệ: `test@eshop.com` / `Test1234!` (`id = 2`, `role = 'user'`).
- Token xác thực JWT được đính kèm trong Header `Authorization: Bearer <token>`.

1.3 Danh sách biến đầu vào và ràng buộc kỹ thuật

Tên biến đầu vào	Kiểu dữ liệu	Miền giá trị hợp lệ (Valid Domain)	Ràng buộc kỹ thuật & Nghiệp vụ (Constraints)
`Authorization` **(JWT Token)**	String (HTTP Header)	Chuỗi `Bearer <valid_token>` hợp lệ, còn hạn.	**Bắt buộc**: Chỉ người dùng đã đăng nhập mới được thanh toán (FR-08, SEC-02).
`Danh sách sản phẩm` **(`items`)**	Array of Objects	Mảng không rỗng, chứa ≥ 1 sản phẩm từ giỏ hàng.	Bắt buộc. Giao diện hiển thị đầy đủ danh sách. Sau thanh toán, giỏ hàng phải bị xóa sạch (FR-08).
`Số lượng` **(`quantity`)**	Integer	Số nguyên dương ≥ 1.	Bắt buộc cho từng dòng sản phẩm. Cấm số 0, số âm, số thập phân (FR-06, FR-07).
`Địa chỉ giao hàng` **(`shipping_address`)**	String	Chuỗi ký tự khác rỗng, độ dài từ 1 đến 255 ký tự.	Bắt buộc (có dấu `*` theo FR-22). Escape an toàn chống XSS, không render HTML (SEC-04).
`Tổng tiền thanh toán` **(`total_amount`)**	Number (Integer)	Không có miền hợp lệ từ Client (Read-only trên UI).	**Ràng buộc an ninh tối quan trọng (FR-08)**: UI cấm sửa trực tiếp; Backend bắt buộc tự tính lại từ CSDL, cấm tin tưởng client.

---

2. PHÂN VÙNG TƯƠNG ĐƯƠNG (EQUIVALENCE PARTITIONING - EP)

Dựa trên các biến đầu vào thuần túy của chức năng Checkout (FR-08), phân chia miền giá trị thành các lớp tương đương:

Biến	Lớp tương đương	Loại	Giá trị đại diện	Mô tả kiểm thử
`Authorization` **(JWT)**	**EC1.1**	Valid	`Bearer <valid_jwt_token>`	Người dùng đã đăng nhập với JWT Token hợp lệ, còn hạn.
	EC1.2	Invalid	`""` (Không gửi Token)	Chưa đăng nhập / Gọi API không có Header Authorization.
`Danh sách SP` **(`items`)**	**EC2.1**	Valid	`[{id: 1, quantity: 1}]`	Giỏ hàng có ít nhất 1 sản phẩm hợp lệ ($\text{length} \geq 1$).
	EC2.2	Invalid	`[]` (Mảng rỗng)	Giỏ hàng trống nhưng gửi yêu cầu thanh toán.
`Số lượng` **(`quantity`)**	**EC3.1**	Valid	`quantity = 1`	Số nguyên dương hợp lệ (≥ 1).
	EC3.2	Invalid	`quantity = 0`	Số lượng bằng 0.
	EC3.3	Invalid	`quantity = -2`	Số lượng là số nguyên âm (< 0).
`Địa chỉ giao hàng`	**EC4.1**	Valid	`"123 Lê Lợi, Q1"`	Chuỗi địa chỉ hợp lệ (1–255 ký tự).
	EC4.2	Invalid	`""` (Rỗng)	Bỏ trống địa chỉ giao hàng (0 ký tự).

Biến	Lớp tương đương	Loại	Giá trị đại diện	Mô tả kiểm thử
	EC4.3	Invalid	`"A".repeat(256)`	Chuỗi địa chỉ vượt quá 255 ký tự.
	EC4.4	Invalid	`"<script>alert('XSS')</script>"`	Chuỗi chứa mã độc HTML/JavaScript (SEC-04).
`Tổng tiền thanh toán`	**EC5.1**	Valid	*(Read-only / Backend tự tính)*	UI khóa chỉnh sửa, Backend tự truy vấn đơn giá từ CSDL.
	EC5.2	Invalid	`total_amount = 1000`	Client cố tình can thiệp sửa giá tiền rẻ mạt để trục lợi.

3. PHÂN TÍCH GIÁ TRỊ BIÊN (BOUNDARY VALUE ANALYSIS - 3-VALUE BVA)

Áp dụng kỹ thuật 3-Value BVA theo chuẩn ISTQB ($Min-1, Min, Min+1, Nominal, Max-1, Max, Max+1$):

3.1 Bảng phân tích giá trị biên 3 giá trị cho FR-08

Biến kiểm thử	Ranh giới (Boundary)	Min - 1	Min	Min + 1	Nominal	Max - 1	Max	Max + 1
`items.length` *(Số SP trong giỏ)*	Tối thiểu 1 sản phẩm (≥ 1)	`0 SP` *(Invalid)*	`1 SP` *(Valid)*	`2 SP` *(Valid)*	`3 SP`	*N/A (Open)*	*N/A (Open)*	*N/A (Open)*
`quantity` *(Số lượng mỗi SP)*	Số nguyên dương tối thiểu 1 (≥ 1)	`0` *(Invalid)*	`1` *(Valid)*	`2` *(Valid)*	`5`	*N/A (Open)*	*N/A (Open)*	*N/A (Open)*
`shipping_address` *(Độ dài chuỗi)*	Độ dài từ 1 đến 255 ký tự	`0 ký tự` *(Invalid)*	`1 ký tự` *(Valid)*	`2 ký tự` *(Valid)*	`25 ký tự`	`254 ký tự` *(Valid)*	`255 ký tự` *(Valid)*	`256 ký tự` *(Invalid)*
`total_amount` *(Giá trị đơn hàng)*	Tổng tiền lớn hơn 0 (> 0)	`0 ₫` *(Invalid)*	`1.000 ₫` *(Valid)*	`2.000 ₫` *(Valid)*	`36.000.000 ₫`	*N/A (Open)*	*N/A (Open)*	*N/A (Open)*

4. KẾT QUẢ THỰC THI KIỂM THỬ THỰC TẾ (TEST EXECUTION RESULTS)

Tất cả 13 kịch bản kiểm thử đã được thực thi trực tiếp trên hệ thống EShop thực tế (Frontend `http://localhost:5173`, Backend `http://localhost:3000`, CSDL `database.sqlite`). Toàn bộ hình ảnh bằng chứng đã được lưu trữ đầy đủ tại thư mục `screenshots/fr08/`.

Mã TC	Kịch bản kiểm thử	Dữ liệu đầu vào (Input)	Kết quả mong đợi (Expected Result)	Kết quả thực tế (Actual Result)	Trạng thái	Bằng chứng (Screenshot)
EXE-01	Kiểm tra GUI, thẻ `<h1>`, đơn vị ₫ & Khóa trường Tổng tiền	Quan sát form; Console: `document.querySelectorAll('h1').length`	Đúng 1 thẻ `<h1>`; ô Tổng tiền ở trạng thái chỉ đọc (disabled); đơn vị ₫.	Ô Tổng tiền thanh toán là thẻ `<input type="number">` cho phép người dùng tự do sửa đổi số tiền tùy ý trên giao diện thay vì ở trạng thái chỉ đọc (Read-only), vi phạm nghiêm trọng đặc tả FR-08; không có thẻ `<h1>` nào (`h1 = 0`, vi phạm FR-21).	**FAIL**	`EXE-01_GUI_TotalAmount_And_H`
EXE-02	Kiểm tra hiển thị danh sách sản phẩm đặt mua	Giỏ hàng có 2 SP: iPhone 15 Pro Max x 1, AirPods Pro 2 x 1	Giao diện hiển thị đầy đủ danh sách SP, số lượng, đơn giá và thành tiền theo FR-08.	Giao diện Checkout hiển thị đầy đủ danh sách sản phẩm đặt mua từ giỏ hàng kèm số lượng và thành tiền đúng định dạng phân cách hàng nghìn (₫).	**PASS**	`EXE-02_GUI_Display_Cart_Item`
EXE-03	Kiểm tra trường bắt buộc Địa chỉ giao hàng và dấu * đỏ	Quan sát form Checkout; tìm kiếm ô nhập Địa chỉ nhận hàng	Có ô nhập Địa chỉ giao hàng có dấu * đỏ (FR-22) hoặc kế thừa địa chỉ mặc định từ hồ sơ cá nhân.	Giao diện Checkout hoàn toàn thiếu ô nhập trường 'Địa chỉ giao hàng' bắt buộc (FR-22) và không kế thừa địa chỉ mặc định từ hồ sơ người dùng (FR-04). Payload gửi lên API POST /api/checkout hoàn toàn không có tham	**FAIL**	`EXE-03_Error_Missing_Shipping_Ad`

Mã TC	Kịch bản kiểm thử	Dữ liệu đầu vào (Input)	Kết quả mong đợi (Expected Result)	Kết quả thực tế (Actual Result)	Trạng thái	Bằng chứng (Screenshot)
				số `shipping_address`.		
EXE-04	Thanh toán thành công luồng chuẩn (Nominal Flow: 36.000.000 ₫)	Đã đăng nhập, giỏ hàng 2 SP ($36,000,000$ ₫), bấm "Xác Nhận Thanh Toán"	Thanh toán thành công (HTTP 200), hiển thị màn hình thành công, lưu đơn hàng `status = 'pending'`.	Thanh toán thành công (HTTP 200 OK), giao diện hiển thị thông báo thành công. Bảng orders trong CSDL SQLite ghi nhận đơn hàng mới với `total_amount = 36,000,000 ₫`, `status = 'pending'`.	**PASS**	`EXE-04_Valid_Checkout_Nomina`
EXE-05	Kiểm tra trạng thái Giỏ hàng sau khi thanh toán thành công	Sau khi đặt hàng ở EXE-04, truy cập `http://localhost:5173/cart`	Giỏ hàng phải được xóa sạch hoàn toàn (`items.length = 0`) theo quy định FR-08 dòng 108.	Sau khi thanh toán thành công, giỏ hàng không hề được làm trống. Truy cập trang Giỏ hàng vẫn thấy nguyên 2 sản phẩm cũ.	**FAIL**	`EXE-05_Bug_Cart_Not_Cleared_Afte`
EXE-06	Giỏ hàng có đúng 1 sản phẩm (Biên Min hợp lệ của `items.length`)	Giỏ hàng có đúng 1 SP: iPhone 15 Pro Max ($30,000,000$ ₫, SL: 1)	Thanh toán thành công (HTTP 200), đơn hàng lưu vào CSDL với tổng tiền 30.000.000 ₫.	Hệ thống xử lý thanh toán thành công với giỏ hàng có đúng 1 sản phẩm (Biên Min hợp lệ của items.length). Đơn hàng được tạo thành công với tổng tiền 30.000.000 ₫.	**PASS**	`EXE-06_BVA_Min_1_Item_Succes`
EXE-07	Đặt hàng khi giỏ hàng trống (Biên Min - 1: `items = []`, tổng tiền 0 ₫)	Gửi request `POST /api/checkout` với `items = []`, `total_amount = 0`	Hệ thống từ chối thanh toán (HTTP 400 Bad Request), thông báo giỏ hàng trống theo FR-08.	Hệ thống cho phép tạo đơn hàng khi giỏ hàng hoàn toàn trống (`items.length = 0`, tổng tiền bằng 0 ₫). Backend `server.js` không kiểm tra số lượng sản phẩm hay tổng tiền hợp lệ, trả về HTTP 200 và lưu đơn hàng rỗng vào CSDL.	**FAIL**	`EXE-07_Bug_BVA_Empty_Cart_Ac`
EXE-08	Đặt hàng với số lượng sản phẩm là số âm (`quantity = -2`)	Gửi request `POST /api/checkout` với `quantity = -2`, `total_amount = -60000000`	Hệ thống từ chối (HTTP 400), báo lỗi số lượng sản phẩm phải là số nguyên dương ≥ 1.	Hệ thống không kiểm tra tính hợp lệ của số lượng sản phẩm, chấp nhận đơn hàng có số lượng âm (`quantity = -2`) với message SUCCESS.	**FAIL**	`EXE-08_Bug_Negative_Quantity`
EXE-09	Bỏ trống Địa chỉ giao hàng (Biên Min - 1: chuỗi rỗng 0 ký tự)	Gửi request `POST /api/checkout` với `shipping_address = ""`	Hệ thống từ chối (HTTP 400), yêu cầu nhập địa chỉ bắt buộc theo FR-22.	Backend không kiểm tra tính bắt buộc của trường Địa chỉ giao hàng, cho phép đặt hàng thành công và lưu chuỗi địa chỉ rỗng vào bảng orders trong CSDL.	**FAIL**	`EXE-09_Bug_BVA_Empty_Address`
EXE-10	Địa chỉ giao hàng tại biên dưới hợp lệ	Gửi request `POST /api/checkout` với `shipping_address = "A"`	Chấp nhận độ dài tối thiểu 1 ký tự, tạo đơn hàng	Hệ thống chấp nhận độ dài tối thiểu 1 ký tự cho trường Địa chỉ	**PASS**	`EXE-10_BVA_Address_Min_1Char`

Mã TC	Kịch bản kiểm thử	Dữ liệu đầu vào (Input)	Kết quả mong đợi (Expected Result)	Kết quả thực tế (Actual Result)	Trạng thái	Bằng chứng (Screenshot)
	(Biên Min: 1 ký tự `"A"`)		thành công (HTTP 200).	giao hàng (Biên Min hợp lệ). Đơn hàng lưu thành công vào CSDL.		
EXE-11	Địa chỉ giao hàng vượt biên trên (Biên Max + 1: chuỗi 256 ký tự)	Gửi request `POST /api/checkout` với `shipping_address = "A".repeat(256)`	Hệ thống từ chối (HTTP 400) hoặc giới hạn độ dài không vượt quá 255 ký tự.	Hệ thống không kiểm soát giới hạn độ dài tối đa 255 ký tự của Địa chỉ giao hàng. Request chứa chuỗi 256 ký tự vẫn được chấp nhận và lưu vào CSDL mà không có cảnh báo lỗi.	**FAIL**	`EXE-11_Bug_BVA_Address_256Chars_`
EXE-12	Gian lận giá thanh toán (Price Tampering: Client gửi 1.000 ₫)	Giỏ hàng thực tế $36,000,000$ ₫, Client gửi payload `total_amount = 1000`	Backend phải tự tính lại tổng tiền từ CSDL ($36,000,000$ ₫) hoặc từ chối đơn hàng gian lận giá.	Lỗ hổng gian lận giá nghiêm trọng: client có thể sửa tổng tiền trên trang thanh toán mà hệ thống tin tưởng vào số tiền này. Đơn hàng mua sản phẩm 36.000.000 ₫ được lưu vào CSDL với số tiền chỉ 1.000 ₫.	**FAIL**	`EXE-12_Bug_Critical_Price_Ta`
EXE-13	Kiểm tra xác thực Token: Thanh toán khi chưa đăng nhập	Gửi request `POST /api/checkout` không có Header `Authorization`	Hệ thống từ chối yêu cầu (HTTP 401 Unauthorized), yêu cầu đăng nhập theo FR-08 và SEC-02.	Hệ thống từ chối yêu cầu thanh toán khi không có JWT Token xác thực.	**PASS**	`EXE-13_Security_Missing_Toke`

5. TỔNG HỢP CÁC LỖI PHÁT HIỆN (DEFECT SUMMARY)

Tổng số test cases thực thi: **13**

- **Passed:** 5/13 (38.46%)
- **Failed (Phát hiện lỗi):** 8/13 (61.54%)

Danh mục 7 lỗi phát hiện được:

1. **BUG-FR08-01 (Critical - Security / Price Tampering)**: Ô Tổng tiền trên giao diện cho phép người dùng tự do nhập số tiền tùy ý; Backend `server.js` không tự tính lại tổng tiền từ CSDL mà tin tưởng hoàn toàn vào `total_amount` do client gửi lên, cho phép mua đơn hàng 36.000.000 ₫ với giá chỉ 1.000 ₫ (vi phạm trực tiếp FR-08).
2. **BUG-FR08-02 (High - State Transition / Data Integrity)**: Giỏ hàng không được làm sạch sau khi thanh toán thành công. `Checkout.jsx` dòng 61 không gọi hàm `clearCart()` và backend không dọn sạch `userCarts`, vi phạm hậu điều kiện của FR-08.
3. **BUG-FR08-03 (High - Missing Mandatory Field & Validation)**: Giao diện Checkout thiếu hoàn toàn ô nhập trường bắt buộc "Địa chỉ giao hàng", và backend chấp nhận lưu đơn hàng không có địa chỉ (rỗng) vào CSDL SQLite (vi phạm FR-08, FR-22).
4. **BUG-FR08-04 (Medium - GUI Standard FR-21)**: Trang Checkout không có thẻ `<h1>` nào (đang dùng thẻ `<h2>`), vi phạm quy chuẩn giao diện chung FR-21.
5. **BUG-FR08-05 (High - Business Logic / Cart Integrity)**: Backend cho phép tạo đơn hàng khi giỏ hàng hoàn toàn trống (`items.length = 0`) và tổng tiền bằng 0 ₫ với HTTP 200 OK.
6. **BUG-FR08-06 (High - Data Integrity)**: Backend chấp nhận tạo đơn hàng với sản phẩm có số lượng âm (`quantity = -2`) với HTTP 200 OK, vi phạm tính toàn vẹn dữ liệu đơn hàng.
7. **BUG-FR08-07 (Medium - Boundary Validation)**: Không kiểm soát giới hạn độ dài tối đa 255 ký tự cho Địa chỉ giao hàng, cho phép lưu chuỗi 256 ký tự vào CSDL mà không có cảnh báo lỗi.